

Multi-Framework Compliance Report

Document:	ABC.txt
Analyzed By:	khizarahmedd3@gmail.com
Analysis Date:	2025-11-24
Overall Score:	59/100
Status:	Non-Compliant
Frameworks Analyzed:	4

Framework Compliance Scores

Framework	Score	Status
Azure Best Practices	92/100	Compliant
GDPR	50/100	Non-Compliant
ISO 27001	44/100	Non-Compliant
ISO 27018	51/100	Non-Compliant

Executive Summary

Multi-framework compliance analysis of the uploaded document. Overall score: 59/100 (Non-Compliant). Analyzed frameworks: azure, gdpr, iso27001, iso27018.

Detailed Framework Analysis

Azure Best Practices

Score:	92/100
Status:	Compliant

Recommendation:
While the document covers many Azure security best practices, enhance the focus on secure administrator workstations by explicitly detailing the minimized build and restrictive permissions configurations. Also, provide more details on the auditing of credentials and security-enhanced remote access procedures.

- Compliant Areas:**
- Identity and Access Management using Microsoft Entra ID, MFA, PIM, and Conditional Access
 - Network Security using NSGs, Azure Firewall, Private Link, DDoS Protection, and Bastion
 - Data Protection using Key Vault, Storage Service Encryption, TLS 1.2+, Always Encrypted, and Azure Information Protection
 - Monitoring and Logging with Azure Monitor, Sentinel, and Defender for Cloud
 - Governance and Compliance using Management Groups, Azure Policy, Purview, and Cost Management
 - Compute Security with Trusted Launch, JIT VM Access, Azure Arc, and automated patching
 - Container Security with AKS, Entra Workload ID, Azure Policy for Kubernetes, and Defender for Containers
 - Storage Security with disabled public blob access, time-limited SAS, and immutability policies

- Key Requirements:**
- Use multi-factor authentication for all users, enforced via Conditional Access policies.
 - Employ Azure Policy to enforce guardrails and compliance standards across subscriptions.
 - Utilize Azure Monitor and Sentinel for comprehensive monitoring, logging, and threat detection.
 - Secure remote access to on-premises web applications through Microsoft Entra application proxy.
 - Restrict access to infrastructure and platform services management in Azure by using multi-factor authentication, X.509 management certificates, and firewall rules.

- Priority Actions:**
1. Document the specific configurations for secure administrator workstations, including minimized build and restrictive permissions.
 2. Detail the auditing processes for credentials and security-enhanced remote access procedures.
 3. Ensure that all services and applications deployed into Azure have appropriate protection measures based on the application's requirements.

GDPR (General Data Protection Regulation)

Score:	50/100
Status:	Partial

Recommendation:
Implement a comprehensive Data Protection Impact Assessment (DPIA) process as mandated by Article 35 of the GDPR, documenting the assessment and mitigation of risks associated with data processing activities. Also, formally designate a Data Protection Officer (DPO) if required by Article 37, and document the rationale for the decision.

Gaps Identified:

- No mention of a Data Protection Officer (DPO) designation or the criteria used to determine if one is required, as per Articles 37-39.
- Lack of explicit mention of a Data Protection Impact Assessment (DPIA) process for high-risk processing activities, as required by Article 35.
- The document does not explicitly address the lawful basis for processing personal data as required by Article 6 (e.g., consent, contract, legal obligation, legitimate interests).
- While DSR fulfillment is mentioned, the document lacks detail on the specific procedures for handling data subject requests (access, rectification, erasure, restriction, portability, objection) as outlined in Articles 12-23.
- The document does not detail the process for obtaining and managing consent where consent is used as the lawful basis for processing.

Compliant Areas:

- Strong security controls are in place, including encryption (Azure Key Vault, SSE, TLS, Always Encrypted), access management (Entra ID, MFA, PIM, Conditional Access), and network security (NSGs, Azure Firewall, Private Link), which contribute to data protection as required by Article 32.
- Monitoring and logging are comprehensive, using Azure Monitor, Sentinel, and Defender for Cloud, which aids in detecting and responding to potential data breaches, supporting Article 33-34 requirements.
- Data residency is enforced using Azure Policy, restricting resource deployment to approved regions, which helps comply with data transfer restrictions.
- The use of Purview Information Protection scanners to automatically discover and label sensitive data (PII/PHI) in Blob Storage and SQL supports data governance and compliance efforts.

Key Requirements:

- Article 5: Data protection principles (lawfulness, fairness, transparency, purpose limitation, data minimization, accuracy, storage limitation, integrity and confidentiality, accountability).
- Article 6: Lawful basis for processing (consent, contract, legal obligation, vital interests, public task, legitimate interests).
- Article 32: Security of processing (implementing appropriate technical and organizational measures to ensure a level of security appropriate to the risk).
- Article 33-34: Notification of a personal data breach to the supervisory authority and communication of a personal data breach to the data subject.
- Article 35: Data protection impact assessment (DPIA) where processing is likely to result in a high risk to the rights and freedoms of natural persons.
- Article 37: Designation of a data protection officer (DPO) where the processing is carried out by a public authority or body, or where the core activities of the controller or the processor consist of processing operations which require regular and systematic monitoring of data subjects on a large scale or consist of processing on a large scale of special categories of data or personal data relating to criminal convictions and offences.

Priority Actions:

1. Conduct a thorough assessment to determine if a Data Protection Officer (DPO) is required under Article 37 and, if so, formally designate one.
2. Develop and implement a Data Protection Impact Assessment (DPIA) process to identify and mitigate risks associated with data processing activities, as mandated by Article 35.
3. Document the lawful basis for processing personal data for each processing activity, ensuring compliance with Article 6.
4. Establish clear procedures for handling data subject requests (DSRs) in accordance with Articles 12-23, including access, rectification, erasure, restriction, portability, and objection.

ISO 27001:2022

Score:	44/100
---------------	--------

Status:	Partial
----------------	---------

Recommendation:

Develop and document a comprehensive Information Security Management System (ISMS) that includes information security policies, risk assessment, and a statement of applicability, as required by ISO 27001:2022. Ensure that all controls are regularly monitored and reviewed for effectiveness.

Gaps Identified:

- Missing documented information security policies (A.5) that address all aspects of information security management as required by ISO 27001:2022.
- Lack of documented procedures for information security incident reporting (6.8) and management (A.16) beyond the use of Microsoft Sentinel.
- Absence of explicit mention of legal, statutory, regulatory, and contractual requirements (5.31) relevant to information security and the organization's approach to meet these requirements.
- No mention of procedures to protect intellectual property rights (5.32).
- No mention of confidentiality or non-disclosure agreements (6.6) with personnel and other relevant interested parties.
- Lack of detail on how remote working (6.7) security measures are implemented and enforced beyond general security controls.
- No mention of physical security perimeters (7.1) and physical entry controls (7.2) to protect areas containing information and associated assets.

Compliant Areas:

- Strong access control measures implemented via Microsoft Entra ID, MFA, PIM, and Conditional Access (A.9).
- Comprehensive use of Azure Key Vault and Managed HSM for encryption key management (A.10).
- Robust network security controls using NSGs, Azure Firewall, Private Link, and DDoS Protection (A.12).
- Extensive monitoring and logging capabilities with Azure Monitor, Sentinel, and Defender for Cloud (A.12).
- Use of Azure Policy and Management Groups for governance and compliance (A.18).

Key Requirements:

- Establish, implement, maintain, and continually improve an information security management system (ISMS).
- Define the scope of the ISMS.
- Conduct information security risk assessments.
- Implement information security controls based on risk assessment results.
- Establish and maintain documented information security policies and procedures.
- Monitor and review the ISMS regularly.
- Manage legal, statutory, regulatory and contractual requirements.

Priority Actions:

1. Develop and document a comprehensive ISMS, including information security policies, risk assessment methodology, and a statement of applicability.
2. Establish and document procedures for information security incident reporting and management, including roles, responsibilities, and escalation paths.
3. Identify and document all relevant legal, statutory, regulatory, and contractual requirements related to information security and ensure compliance.

ISO 27018:2019

Score:	51/100
Status:	Partial

Recommendation:

Implement explicit procedures for handling Data Subject Requests (DSRs) beyond simply leveraging the Azure Data Privacy Portal. Detail the process for verifying the identity of the requestor, the types of PII that can be accessed/rectified/erased, and the timelines for fulfilling each type of request. Also, establish a clear policy regarding PII breach notification, including timelines, responsible parties, and communication channels, and integrate this policy with the existing monitoring and logging infrastructure.

Gaps Identified:

- Lack of explicit procedures for handling Data Subject Requests (DSRs) beyond using the Azure Data Privacy Portal. The document mentions leveraging the portal but doesn't detail the specific processes for verification, access, rectification, and erasure.
- Missing details on consent management. The document doesn't describe how consent is obtained, recorded, and managed for PII processing.
- Insufficient detail on PII breach notification procedures. While monitoring and logging are mentioned, the document lacks specifics on how PII breaches are detected, reported, and remediated, including timelines and responsible parties.
- The document does not explicitly address the allocation of responsibilities between the cloud service provider and the cloud service customer regarding PII protection, especially concerning application layer controls in different cloud service models (IaaS, PaaS, SaaS).

Compliant Areas:

- Strong identity and access management controls using Microsoft Entra ID, MFA, PIM, and Conditional Access, which indirectly supports PII protection by limiting unauthorized access.
- Data protection measures including Azure Key Vault, Storage Service Encryption, TLS 1.2+, Always Encrypted, and Azure Information Protection, which directly contribute to PII confidentiality and integrity.
- Comprehensive monitoring and logging using Azure Monitor, Sentinel, and Defender for Cloud, which can help detect and respond to security incidents involving PII.
- Use of Azure Policy and Management Groups to enforce data residency and other compliance requirements, which indirectly supports PII protection by ensuring data is stored in approved regions.

Key Requirements:

- Consent management for PII processing.
- Support for data subject rights (access, rectification, erasure).
- Transparency regarding PII processing activities.
- PII breach notification procedures.
- Contractual agreements that clearly allocate responsibilities between the cloud service provider and the cloud service customer regarding PII protection.

Priority Actions:

1. Develop and document detailed procedures for handling Data Subject Requests (DSRs), including identity verification, access, rectification, erasure, and timelines.
2. Establish a comprehensive PII breach notification policy, including detection, reporting, remediation, timelines, responsible parties, and communication channels, and integrate it with the existing monitoring and logging infrastructure.
3. Implement a consent management system to obtain, record, and manage consent for PII processing, ensuring compliance with applicable regulations.
4. Define and document the allocation of responsibilities between the cloud service provider and the cloud service customer regarding PII protection, especially concerning application layer controls in different cloud service models (IaaS, PaaS, SaaS), and incorporate this into contractual agreements.